Wireless & Mobile Security Risk Assessment

Disclaimer: This assessment was performed in a controlled educational environment for learning processes. No production systems were targeted or accessed during this exercise.

Project Overview

A comprehensive wireless and mobile device security assessment of a 35-user business operating from a three-story headquarters in response to a recent security incident. At present, employees occupy two of the three floors in the building. The wireless network consists of eight Wireless Access Points (WAPs) connected to a gigabit managed switch. In addition, the company has a very permissive mobile device and Bring Your Own Device (BYOD) policies with no security configuration required. I evaluated WLAN security risks, the BYOD policy, physical access concerns, mobile device exposure, security governance, and compliance considerations. I then developed risk-based recommendations aligned with NIST guidance and information security best practices.

Objectives

• Identify wireless network security weaknesses
• Assess mobile device and BYOD policies
• Recommend technical and administrative controls to improve the organization's security posture through defense-in-depth strategies

Key Findings

• HQ's wireless signals tested via spectrum analyzer. One WAP's Wi-Fi signal reaches far outside the building, enabling access the company's wireless network from the parking lot.
• The third floor of the building has Wi-Fi coverage via three WAPs, even though it is unoccupied. The Ethernet ports are also fully functional; an attacker who can access the third floor can also plug directly into the company's network, as there are no access control policies in effect.
• Eight sales employees are on the road for 90% of the month with company issued laptops, tablets, and iPhones. There is currently no Mobile Device Management policy or any security requirements, not even mandatory passcodes. Should a company device be lost or stolen, confidential company data would be exposed.
• The BYOD policy has no required security configurations, which put's company data at risk.

Finding	Likelihood	Impact	Severity
WAP Signal Leakage	High	High	High
Unsecured Third Floor	High	Critical	Critical
Unmanaged Mobile Devices	High	Critical	Critical
Insecure BYOD Program	High	High	High

Likely Threat Actors

- External attackers
- Rogue insiders/disgruntled employees
- Device thieves

Possible Attack Techniques

- Rogue access points
- Evil Twin attacks
- Packet sniffing
- Credential theft
- Physical intrusion

Security Recommendations

- Reduce wireless attack surface through proper access point placement and signal-strength management.
- Implement Mobile Device Management (MDM) solutions that enforce encryption, remote wipe, asset tracking, and patch management. This is especially important for company devices that often leave the building (i.e. the Sales team).
- Deploy Multi-Factor Authentication (MFA) to protect user accounts from unauthorized access.
- I strongly recommend the company purchase company devices for employee use; if this is not possible, then a policy must be created and enforced to bring security controls to the BYOD policy.
- Strengthen physical security of HQ through access controls, cameras, and monitoring.
- Create and implement an access control policy to ensure only vetted and securely configured devices are allowed on the network. This should apply to Wi-Fi and Ethernet connections.

Compliance and Governance

Assessed security recommendations against NIST wireless security guidance, NIST mobile device security guidance, and organizational governance requirements supporting future regulatory compliance efforts.